

Senario

Forela's Network is constantly under attack. The security system raised an alert about an old admin account requesting a ticket from KDC on a domain controller. Inventory shows that this user account is not used as of now so you are tasked to take a look at this. This may be an AsREP roasting attack as anyone can request any user's ticket which has preauthentication disabled.

Analysis

AsRep Roasting in its nature relies on Accounts being configured to “PreAuthNotRequired” which means the user doesn't have to be authenticated via kerberos to request a ticket which is the Authentication service request (Asreq) and the response is the ticket encrypted with the user password hash which is Authentication Service Reply (Asrep) . attackers can crack the hash offline to obtain cleartext credentials .

We are provided with just single Event Logs file so im going to make it in readable format as i cant run these binaries in my Kali Machine

```
┌──(kali㉿kali)-[~/Htb/Campfire-2]
└─$ evtxexport Security.evtx > EventLogs.xml
```

Start Filtering for All Successful TGT requests in the Log

```
┌──(kali㉿kali)-[~/Htb/Campfire-2]
└─$ cat EventLogs.xml | grep -i 4768 -A 10 -B 8 -m 1
```

The command will find the first time any user showed up in the logs for successful TGT request (EventID 4768) and will print the full event log with its information. Scrolling each by incrementing the value of -m we can see another event from arthur.kyle the unusual Account besides builtin Administrator Account , Also observing the String No 9 show the value of 0 which means this does not request pre-authentication . all other logs shows the builtin Admin account requesting a TGT so we are confident that the suspected account requesting a TGT at **2024-05-29 06:36:40** was **arthur.kyle**

```
Event number                    : 74
Creation time                   : May 29, 2024 06:36:40.246362700 UTC
Written time                    : May 29, 2024 06:36:40.246362700 UTC
Event version                   : 0
Event level                     : Information (0)
Computer name                   : DC01.forela.local
Source name                     : Microsoft-Windows-Security-Auditing
Channel name                    : Security
Event identifier                : 0×000012a0 (4768)
Number of strings               : 14
String: 1                       : arthur.kyle
String: 2                       : forela.local
String: 3                       : S-1-5-21-3239415629-1862073780-2394361899-1601
String: 4                       : krbtgt
String: 5                       : S-1-5-21-3239415629-1862073780-2394361899-502
String: 6                       : 0×40800010
String: 7                       : 0×00000000
String: 8                       : 0×00000017
String: 9                       : 0
String: 10                      : ::ffff:172.17.79.129
String: 11                      : 61965
String: 12                      :
String: 13                      :
```

His Account SID is **S-1-5-21-3239415629-1862073780-2394361899-1601** with the IP Address of **172.17.79.129** .
Going through the logs again but filtering for the Attacker IP to see what he did after gaining the TGT hash

```
┌──(kali㉿kali)-[~/Htb/Campfire-2]
└─$ cat EventLogs.xml | grep -i 172.17.79.129
```

```
Event identifier                : 0×000012a1 (4769)
Number of strings               : 11
String: 1                       : happy.grunwald@FORELA.LOCAL
String: 2                       : FORELA.LOCAL
String: 3                       : DC01$
String: 4                       : S-1-5-21-3239415629-1862073780-2394361899-1000
String: 5                       : 0×40810000
String: 6                       : 0×00000012
String: 7                       : ::ffff:172.17.79.129
String: 8                       : 61975
String: 9                       : 0×00000000
String: 10                      : {543ACECF-87DD-45D9-CF0D-6C1F28070DC3}
String: 11                      : -
```

We can see the same Attacker Requested a TGS (EventID 4769) as the user **happy.grunwald** , which means he performed ASREP Roasting and Password spraying Successfully and pivoted into another account .

Remediation

Disable Kerberos preauthentication exceptions to stop AS-REP Roasting, enforce complex password policies to defeat password spraying, and deploy smart lockouts while monitoring Event IDs 4768 and 4625 to block malicious IPs.